

Clase 178 — Purple teaming

Parte: **7 — Red Team y operaciones ofensivas** · Fuente: *MITRE ATT&CK / SANS purple team methodology* 🕒 Duración estimada: **100 min** · Nivel: **Avanzado**

Objetivo

Convertir el conocimiento ofensivo en mejora defensiva mediante el purple teaming: la colaboración estructurada entre Red y Blue para probar, medir y afinar detecciones técnica por técnica. El alumno aprenderá a ejecutar un ciclo purple (planificar TTP → ejecutar → observar → ajustar detección → reejecutar) y a documentar la cobertura resultante en ATT&CK.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Explicar** la diferencia entre red, blue y purple team.
2. **Ejecutar** un ciclo purple sobre una técnica concreta.
3. **Medir** la cobertura de detección con ATT&CK Navigator.
4. **Escribir/afinar** una detección basada en la observación de un TTP.
5. **Documentar** hallazgos accionables para el SOC.

Temas

#	Tema	Por qué importa
1	Red vs Blue vs Purple	Colaboración en lugar de competición
2	Ciclo purple	Ejecutar → observar → ajustar → reejecutar
3	Selección de TTPs	Priorizar por riesgo y cobertura
4	Instrumentación defensiva	Sysmon, EDR, SIEM listos para observar
5	Detection engineering	De la observación a la regla
6	Métricas de cobertura	Navigator: detectado/no detectado
7	Documentación	Hallazgos accionables

Definiciones y características

- **Purple team:** colaboración Red+Blue en tiempo real para mejorar detección. Característica: objetivo compartido, no adversarial.
- **Ciclo purple:** iterar ejecución de un TTP y ajuste de la detección hasta cubrirlo. Característica: iterativo y medible.
- **Detection engineering:** disciplina de crear y afinar reglas de detección. Característica: nace de observar TTPs reales.

- **Cobertura ATT&CK:** porcentaje de técnicas relevantes que se detectan. Característica: se visualiza en Navigator.
- **True/false positive:** alerta correcta vs falsa. Característica: el ciclo purple busca maximizar TP y reducir FP.
- **Detección vs prevención:** alertar sobre vs bloquear. Característica: el purple team mide ambas.

Herramientas y preparación

- El AD lab con instrumentación defensiva: **Sysmon** (config SwiftOnSecurity), un SIEM (Elastic/Wazuh/Splunk free) y/o EDR.
- **Atomic Red Team** (Clase 180) para ejecutar TTPs atómicos reproducibles.
- **ATT&CK Navigator** para la matriz de cobertura.
- Las técnicas ofensivas de las clases anteriores como insumos a detectar.

⚠ El purple teaming se ejecuta en el laboratorio con acuerdo de ambos equipos. Es intrínsecamente autorizado (Red y Blue trabajan juntos), pero las técnicas ofensivas siguen la misma ética: solo en el entorno propio del ejercicio.

Laboratorio guiado

1. **Prepara la instrumentación.** Instala Sysmon con una config robusta y envía eventos a tu SIEM; verifica que lleguen.
2. **Elige un TTP.** Toma Kerberoasting (T1558.003) de la Clase 171.
3. **Ejecuta y observa (ronda 1).** Lanza el ataque y busca en el SIEM el evento 4769 con etype RC4; comprueba si existe una regla que alerte.
4. **Ajusta la detección.** Escribe/afina una regla que alerte ante múltiples 4769 RC4 en poco tiempo desde un mismo origen.
5. **Reejecuta (ronda 2).** Vuelve a lanzar Kerberoasting y confirma que ahora sí dispara la alerta; reduce falsos positivos si aparecen.
6. **Mide cobertura.** En Navigator, marca el TTP como "detectado" (verde) y repite el ciclo con 2–3 técnicas más (PtH, DCSync).
7. **Documenta.** Registra por técnica: qué se ejecutó, qué se observó, la regla creada y el estado de cobertura.

Ejercicios

1. Explica el ciclo purple con un diagrama.
2. Ejecuta un ciclo purple completo sobre Pass-the-Hash.
3. Escribe una regla de detección para DCSync (evento 4662).
4. Construye una capa de cobertura en Navigator con 5 técnicas.
5. Reduce un falso positivo de una de tus reglas y documenta cómo.
6. Redacta un hallazgo accionable para el SOC a partir de una técnica no detectada.

Reto verificable

Ejecuta un **ciclo purple completo** sobre al menos 3 técnicas de esta parte: demuestra que inicialmente no se detectaban (o se detectaban mal) y que tras afinar reglas quedan cubiertas, reflejándolo en un layer de Navigator. **Criterio de aceptación:** para cada técnica presentas la ejecución, la observación en el SIEM, la regla creada/afinada y la reejecución que confirma la detección; el layer de Navigator muestra las 3 técnicas en verde con comentario.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
No llegan eventos al SIEM	Sysmon/forwarder mal configurado; valida el pipeline primero
La regla no dispara	Campo/etype equivocado; inspecciona el evento crudo antes de escribir la regla
Muchos falsos positivos	Regla demasiado amplia; añade umbrales y contexto
Cobertura inflada	Marcaste "detectado" sin verificar; exige reejecución que confirme
Red y Blue no coordinan	Falta agenda del ciclo; define quién ejecuta y quién observa cada TTP

Preguntas frecuentes

 **¿Purple team es un equipo o una actividad?** Sobre todo una actividad/función: Red y Blue colaborando. Algunas organizaciones tienen un rol dedicado, pero el valor está en el proceso.

 **¿En qué se diferencia de un Red Team normal?** El Red Team clásico prueba la detección sin avisar; el purple team colabora abiertamente para **mejorarla** técnica por técnica. Son complementarios.

 **¿Necesito Atomic Red Team?** Ayuda mucho porque da TTPs atómicos reproducibles (Clase 180), pero puedes ejecutar las técnicas manualmente de las clases anteriores.

Referencias

- MITRE ATT&CK — *Detections & Data Sources*. <https://attack.mitre.org/datasources/>
- SANS — *Purple Team methodology* / cursos SEC599.
- Atomic Red Team. <https://github.com/redcanaryco/atomic-red-team>
- Sysmon config (SwiftOnSecurity). <https://github.com/SwiftOnSecurity/sysmon-config>

Siguiente clase

Clase 179 - Reporte y metricas de Red Team